한클래스 관리자 구축 기획안

전체 기능을 단계적으로 구축하기 위한 범위·선행 결정·운영 기준 | 1/2 기능과 설계

목표: 강의 운영, 회원 지원, 콘텐츠 관리, 행동 분석과 실험을 한곳에서 수행한다. 현재 데모와 향후 실제 판매를 구분하며, 아래 항목은 구현 완료 보고가 아닌 제안 범위다.

01 전체 메뉴와 관리 항목

메뉴	필수 기능·고려 요소
대시보드	선택 기간의 방문·회원·데모 신청, 미처리 문의·신고, 저장 오류. 집계 시각·데이터 출처·처리 화면 링크 표시.
강의·자료	제목·분야·가격·썸네일·목표·결과물·준비물·커리큘럼·영상·파일 관리. 제작/공개/판매 상태 분리, 미리보기·검수·공개·되돌리기.
회원·등급	계정 검색·상태·데모 수강 내역, 제한·해제·탈퇴 처리. 운영 권한과 활동 등급 분리, 변경 사유·이력. 자기보고 체크를 실력 인증으로 사용하지 않음.
수강·주문	신청·취소·중복·오류 조회, 데모/실구매 별도 구분. 향후 결제·환불·분쟁·정산·이용 권한 회수까지 연결. 임의 매출 생성 금지.
게시물·공지	초안·예약·공개·숨김, 댓글·신고·스팸 처리, 첨부파일·외부 링크 관리. 조치 이유·복구·작성자 안내. 영구 삭제는 별도 권한·확인.
문의·지원	접수 유형·담당자·답변 상태·처리 기한, 답변 템플릿·FAQ. 개인정보 최소 열람, 비밀키·민감정보 입력 금지 안내.
통계·분석	GA4 유입·기기·강의 탐색 흐름 + 서버 회원·신청 집계. 검색 결과 없음, 조회→신청. 정의·분모·기간·갱신 지연 명시, 수치 불일치 설명.
A/B 실험	가설·단일 변경 변수·대상·버전·배정 비율·기간·지표·중단 조건. A/B 미리보기, 안정적 배정·노출 기록·회고·판단 보류. 접근성 오류는 즉시 수정.
설정·감사	운영자 초대·권한 회수, 정책 버전·공지·알림, 작업 이력·백업·복구. 비밀키는 서버 환경에서만 관리.

02 개발 전에 확정할 결정

① 기존 카카오 인증·Supabase 연결·회원 ID 매핑을 먼저 확인하고 재사용한다. 브라우저 로그인 표시만 있는지, 서버가 검증 가능한 세션인지 구분한다. 공유 프로젝트 유지/분리, 무료 한도·요금·개발/운영 환경·배포 방식을 결정한다.

② 일반 회원 / 콘텐츠 운영자 / 회원지원 / 통계 열람 / 최고 관리자의 권한표와 최초 관리자 지정 방법을 확정한다. 운영자 권한과 회원 활동 등급을 같은 필드로 사용하지 않는다.

③ 강의 검수·공개 책임자, 게시물 신고·이의제기, 신청 취소, 회원 제한·탈퇴, 개인정보 보존·파기, 통계 안내·필요한 동의, 문의 응답 기준을 정한다. 실제 판매 정책은 결제 도입 전에 별도로 검토한다.

03 데이터·상태를 먼저 설계

회원·역할·등급 이력 / 강의·차시·자료 버전 / 데모 신청·학습 진행 / 게시물·댓글·신고 / 문의·답변 / 실험·배정·노출 / 관리자 감사 로그를 분리한다. 실판매 도입 시 주문·결제·환불·수강 권한을 별도로 추가한다.

신청은 사용자–강의 중복 방지, 날짜·시간대와 상태 전이 규칙, 수정 충돌·삭제·복구 기준을 정의한다. 브라우저 기록은 실제 구매로 자동 이전하지 않는다. 활동 등급·학습 체크도 유료 콘텐츠 권한을 만들지 않는다.

구축 순서와 출시 조건

2/2 실행·보안·검증 | 전체 범위를 한 번에 공개하지 않고 단계별 완료 기준으로 관리

04 권장 구축 순서와 단계별 산출물

순서	작업	완료 조건·산출물
1 · 현황 확인	현재 코드·인증·DB·GA4·배포·저장 위치 점검	기존 기능/누락/재사용 목록, 외부 설정·결정 목록. 설정값과 비밀키는 채팅에 공유하지 않음.
2 · 설계 확정	메뉴·업무 흐름·권한표·DB·측정 정의	화면 설계, 데이터 사전·상태 전이, API·권한 정책, 운영 정책 초안. 구현 범위와 제외 범위 합의.
3 · 운영 기반	관리자 인증·서버 권한·감사 로그·백업	운영자별 허용 작업 검증, 첫 관리자 안전 지정, 개발/운영 분리 및 DB 변경·복구 절차.
4 · 핵심 운영	강의·회원·등급·데모 신청 관리	초안→검수→공개, 기록 조회·변경·취소와 실패 재시도. 권한 없는 변경·중복 신청 차단.
5 · 지원·분석	게시물·신고·문의·GA4·서버 집계	통계 정의·접근 범위, 신고·답변 처리, 삭제·복구 검증. 운영자·봇·테스트 유입 구분 기준.
6 · 실험 운영	A/B 배정·노출·결과·중단 기능	버전별 일관된 배정, 지표의 분모·관찰 기간, 즉시 중단·복구. 적은 표본은 성과 확정 금지.
7 · 출시·운영	통합 검증·운영 매뉴얼·모니터링	오류·권한·개인정보 점검, 복구 리허설·책임자·대응 연락 체계. 단계별 승인 후 공개.
판매 전 추가	결제 사업자·환불·정산·콘텐츠 권한	서버 결제 검증, 웹훅 재처리·위변조·중복 결제, 부분 환불·권한 회수. 카드정보 직접 수집 금지.

05 보안·개인정보: 구현에 포함할 필수 조건

• 관리자 페이지의 메뉴 숨김만으로 보호하지 않는다. 서버에서 토큰·역할·작업 범위를 검증하고 DB·파일 저장소에도 접근 정책을 적용한다. 클라이언트가 보낸 사용자 ID나 등급을 신뢰하지 않는다.

• 관리자 계정 공유 금지, 권한 최소화, 운영자 다중인증·세션 만료·권한 회수 반영을 검토한다. 관리자 키는 서버에만 보관하고 목록 다운로드도 별도 권한·이력·최소 항목으로 제한한다.

• 로그는 운영자·대상·작업·시각·사유·변경 항목을 기록하되 비밀번호·토큰·자소서 원문을 저장하지 않는다. 게시물/첨부 입력 검증·XSS 방지·업로드 제한·요청 제한과 인증 방식에 맞는 요청 위조 방어를 적용한다.

• 유료 영상·파일은 공개 정적 경로에 두지 않는다. 서버 수강 권한 검증과 만료 링크 등 전달 방식을 설계한다. 탈퇴·파기·법정 보존 대상·백업 만료를 구분하고, 복구 시 삭제 정보가 되살아나지 않게 처리한다.

06 통계·실험의 판단 기준

GA4 사용자 ≠ 가입 회원 ≠ 수강 신청자다. 실제 결제 없는 데모는 demo_ 이벤트로 분리하고 매출로 집계하지 않는다. 검색·자소서·기업명·이메일 원문은 전송하지 않는다. 조회·신청 지표는 중복 제거 단위와 기간을 고정한다. 동의·차단·지연에 따른 누락을 표시한다.

A/B는 목적·버전·배정 단위·노출 조건·주요 지표·안전 지표를 시작 전에 기록한다. 버튼 클릭 상승만으로 학습 효과를 주장하지 않는다. 트래픽이 적으면 사용자 과제 관찰을 병행하고 '판단 보류'를 허용한다.

07 최종 검증 체크리스트·운영 준비

☐ 일반 회원의 관리자 접근·타인 기록 조회 차단 ☐ 운영자 역할별 허용/거부·권한 회수 확인 ☐ 중복 신청·동시 수정·잘못된 상태 전이 차단 ☐ 로그아웃/계정 전환 시 이전 정보 제거 ☐ 저장·조회·파일 실패와 재시도·빈 화면

☐ 강의 공개/숨김·게시물 복구·신고/문의 이력 ☐ 통계 수집·중복·운영자 제외·개인정보 유출 확인 ☐ 실험 배정·노출·중단·복구 ☐ 모바일·키보드·브라우저 오류·기존 테스트/빌드 ☐ 백업 복원·DB 마이그레이션·장애 알림·비용 한도

출시 전 남길 문서: 기능 명세·권한표·데이터/지표 사전·운영 매뉴얼·개인정보/콘텐츠 정책·테스트 결과·복구 절차·후속 일정. 현재 인증·공유 DB·실수집 상태는 개발 착수 시 재확인한다.